

PENETRATION TESTING REPORT: SCANNING AND ENUMERATION

NAME

Solomon

DATE

April 14, 2026

ROLE

Junior Penetration Tester

RECONNAISSANCE SUMMARY

What was the objective of your reconnaissance process?

The objective was to identify live hosts within the staging environment, map the available attack surface of the Metasploitable 2 target, and enumerate specific service versions to identify misconfigurations or known vulnerabilities prior to an external audit.

What network range did you scan?

The Flatiron NAT Network range: 192.168.100.0/24.

What scanning strategy did you choose and why?

I utilized a tiered strategy: first, a Ping Scan (-sn) for rapid host discovery without alerting security controls, followed by a SYN Stealth Scan (-sS) with Service Version Detection (-sV). This allowed for a balance between speed and data depth, ensuring I had the exact version numbers needed for vulnerability research.

Were there any challenges identifying the target system?

Identification was straightforward; the target at 192.168.100.3 responded with an unusually high number of open ports (23), which is a characteristic "fingerprint" of the Metasploitable 2 vulnerable framework.

NMAP SCAN RESULTS (HOST DISCOVERY + PORT SCANNING)

What Nmap scan(s) did you run?

1. nmap -sn 192.168.100.0/24: Host discovery to map the subnet.
2. nmap -sV 192.168.100.3: Service version detection to identify software versions.
3. nmap -sV -A 192.168.100.3: Aggressive scan for OS detection and script scanning.

How many hosts were identified as "up" on the network?

4 hosts were identified as active on the subnet.

What was the IP address of the target system?

192.168.100.3

List the open ports and their associated services from your target scan:

Port 21: FTP (vsftpd 2.3.4)
Port 22: SSH (OpenSSH 4.7p1)
Port 23: Telnet (Linux telnetd)
Port 25: SMTP (Postfix smtpd)
Port 80: HTTP (Apache httpd 2.2.8)
Port 139/445: NetBIOS/SMB (Samba 3.X)
Port 3306: MySQL (5.0.51a)
Port 5432: PostgreSQL (8.3.0)

SMB ENUMERATION

What tool did you use for SMB enumeration?

Enum4linux and Nmap scripts (--script smb-enum-shares).

What specific information were you able to retrieve from the SMB service?

I retrieved local user accounts (user, service, etc.), OS information (Unix), and identified several accessible shares, including /tmp and /var/www.

Were there any interesting user accounts or shares discovered?

Yes, the "tmp" share was accessible without credentials, and the "service" user account appeared to have broad permissions, making it a high-value target for credential-based attacks.

SERVICE INVESTIGATION & ANALYSIS

Which services did you decide to investigate more closely?

I focused on Port 21 (FTP) and Port 445 (SMB).

For each service, what potential vulnerabilities or misconfigurations did you find?

Port 21: The vsftpd 2.3.4 version is vulnerable to a known backdoor command execution (CVE-2011-2523).
Port 445: The Samba 3.0.20 version is vulnerable to "usermap script" Remote Code Execution (CVE-2007-2447).

Why do these services represent a significant risk to the client?

Both vulnerabilities allow an attacker to gain a root shell immediately. In a healthcare environment, this could lead to the total compromise of patient records and the deployment of ransomware across the network.

NETWORK SCAN STRATEGY REFLECTION

Did you change your scan type at any point?

Yes, I increased verbosity (-v) to see open ports in real-time and added -A once the target was isolated to extract deeper metadata like SSH keys and SMB share names.

How did different scan techniques affect your results?

The simple Ping scan found the host but told me nothing of the risk. The sV scan was the "turning point," as identifying vsftpd 2.3.4 immediately changed the assessment from "recon" to "confirmed vulnerability."

What trade-offs exist between stealth and aggressive scans?

Stealth scans (-sS) are less likely to be logged by a firewall but take longer and provide less detail. Aggressive scans (-A) provide a wealth of data (OS, scripts, traceroute) but are very "noisy" and can easily trigger an IPS or even crash fragile legacy services.

LESSONS LEARNED

What were your biggest takeaways about scanning and enumeration?

The version number is everything. A port being "open" is just a lead; knowing the specific version of the software running on that port is what allows a tester to find the exact "key" (exploit) to the lock.

What would you do differently in a real-world pentest environment?

I would be much more cautious with the -A flag. In a healthcare setting, I would use manual banner grabbing via nc or telnet for specific ports to ensure I don't disrupt sensitive medical devices that might be sensitive to Nmap's automated scripts.